PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Dimensionnement et sélection des mécanismes cryptographiques

03-980 ANSSI - Mécanismes cryptographiques, règles de dimensionnement, sélection des algorithmes et analyse de risque — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le référentiel de dimensionnement définit les règles de conformité et les recommandations, mais exclut la gestion des clés et l'évaluation.
2. La sécurité post-quantique repose sur des problèmes mathématiques résistants au calcul quantique ou sur l'usage de mécanismes symétriques conformes.
3. La migration vers des mécanismes post-quantiques est estimée à 10 ans et nécessite un lancement immédiat pour protéger les actifs critiques.

Les trois documents de référence

Notion	À retenir
Référentiel de dimensionnement	Guide `ANSSI-PG-083` (v**3.00** du **20 mars 2026**) : définit **règles** (conformité) et **recommandations**. Exclut gestion des clés, mécanismes recommandés, canaux auxiliaires et évaluation.
Guide de sélection	Guide de sélection d'algorithmes cryptographiques (v**1.0** du **8 mars 2021**) : fournit la **liste des mécanismes recommandés** et des **mises en garde pratiques**.
Analyse de risque 2026	Analyse de risque de haut niveau sur le **chiffrement** et usages de la cryptographie : incite les **organisations utilisatrices non spécialistes** à lancer la **transition post-quantique** dès maintenant.

Recommandations générales et aléa

Notion	À retenir
RecoSécuLongTerme	Usage prévu après le **1er janvier 2030** ou risque d'attaque rétroactive : viser une **sécurité post-quantique** (un échange **Diffie-Hellman** enregistré pourra être compromis).
RecoMécanismesÉprouvés	Employer des mécanismes **éprouvés** et reconnus par la communauté académique.
Génération d'aléa	Retraitement algorithmique avec état interne **≥ 192 bits** ; sans générateur physique, **mémoire non volatile**.

Synthèse de la cryptographie symétrique

Notion	À retenir
Taille de clé et de bloc	Clé symétrique : minimum **128 bits** (**192 bits** si post-quantique) ; 64 bits insuffisants, ≤ ~100 bits risqué. Bloc : minimum **128 bits** (paradoxe des anniversaires).
Modes et intégrité	Mode **non déterministe** recommandé. Intégrité : pas d'attaque en moins de **2^128** opérations ; motif ≥ **96 bits** si sécurité indépendante de la taille des messages.
Hachage	Empreinte : minimum **256 bits** (**384 bits** si post-quantique). Collision : de l'ordre de **2^(h/2)** ; préimage : **2^h**. Éviter toute fonction à attaque partielle connue.

Synthèse de la cryptographie asymétrique

Notion	À retenir
Hypothèses de sécurité	Adversaire classique : problème mathématique éprouvé ou mécanisme symétrique conforme. Sécurité post-quantique : problème résistant au calcul quantique ou mécanisme symétrique conforme.
RSA et logarithme discret	RSA : **2048 bits** jusqu'à fin **2030**, **3072 bits** dès **2031** (3072 recommandé dès maintenant) ; exposants publics **> 65536**, **≤ 256 bits**. Log discret : 2048 puis 3072 bits ; sous-groupes et courbes elliptiques : premier **≥ 250 bits**.
Réseaux euclidiens	Problèmes **LWE** et **SIS** (structurés ou non) : attaque quantique doit être au moins aussi coûteuse que résolution **SVP** dans un réseau générique de **dimension 400**.
Authentification et clé	Secret faible entropie : aucune recherche exhaustive hors ligne possible. Confidentialité persistante recommandée : secret temporaire effacé au plus tard à la **fin de chaque session**.

Guide de sélection 2021

Notion	À retenir
Mécanismes recommandés	**AES** (**128**, **192**, **256** bits), modes authentifiés (**Encrypt-then-MAC**, **GCM**, **CCM**, **EAX**, **ChaCha20-Poly1305**), **HMAC** (sur hachage recommandé), **SIV**, **AES-KeyWrap**, **PBKDF2**.
Mises en garde	**Une clé, un usage** : ne pas réutiliser une clé entre mécanismes (ex: **AES-CBC** et **AES-CBC-MAC**). Utiliser des **mécanismes complets**, des **bibliothèques éprouvées** et éviter la **créativité** (secret des spécifications).

Analyse de risque post-quantique 2026

Notion	À retenir
Le constat	Vulnérabilité de **RSA**, **ECDH** et **ECDSA**. Migration estimée à **10 ans** : nécessite un début immédiat pour protéger les actifs critiques.
Risques métier	1. **Décryptement rétroactif** (confidentialité/espionnage), 2. **Décryptement temps réel**, 3. **Falsification de documents** (intégrité), 4. **Prise de contrôle équipements** (authentification), 5. **Chaîne d'approvisionnement**.
Démarche	1. **Évaluer criticité** (inventaire), 2. **Construire stratégie**, 3. **Mettre en œuvre**, 4. **Gouvernance continue**. Priorisation **P1** à **P3** selon durée de confidentialité, vie, exposition et complexité.

Pièges et confusions

- ⚠ Confondre la règle (principe de conformité) avec la recommandation (bonne pratique de sécurité).
- ⚠ Confondre le déchiffrement (avec la clé) et le décryptement (sans la clé).
- ⚠ Réutiliser une même clé pour plusieurs mécanismes différents.
- ⚠ Utiliser RSA avec une taille de 2048 bits après l'échéance de 2030.
- ⚠ Confondre la primitive (composant élémentaire) et la construction (mécanisme complet).

Sigles et définitions

MAC	Code d'authentification de message garantissant l'intégrité et l'origine via une clé secrète.
PFS	Confidentialité persistante garantissant que la compromission d'un secret de long terme n'affecte pas les sessions passées.
XOF	Fonction à sortie extensible.
Inventaire cryptographique	Recensement des données, systèmes, équipements et mécanismes concernés par la migration post-quantique.
Mécanisme post-quantique	Mécanisme asymétrique dont la sécurité repose sur un problème résistant au calcul quantique ou un mécanisme symétrique conforme.

Auto-test

1. Quel est le minimum recommandé pour une clé symétrique en mode post-quantique ?
2. Quelle est la taille minimale d'un bloc en cryptographie symétrique ?
3. À partir de quelle année RSA doit-il passer à 3072 bits ?
4. Quelle est la complexité d'une attaque par collision sur une fonction de hachage ?
5. Combien de temps la migration post-quantique est-elle estimée prendre ?

Réponses : **1.** 192 bits · **2.** 128 bits · **3.** 2031 · **4.** de l'ordre de $2^{(h/2)}$, h étant la taille d'empreinte · **5.** 10 ans

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.